After-action report: Ledgerline cloud credential drill, Q4 2026

Ledgerline

Scenario: Leaked AWS Key and Surprise Cloud Bill at a Small SaaS Company (Cloud credential compromise, generated from the company's plan)

Held Oct 14, 2026, 10:39 PM to Oct 14, 2026, 10:47 PM, 8 minutes

Facilitator: Jung Ko. Plan version tested: 2 (approved). Obligations: SOC 2, Cyber insurance only.

1 of 3 invited participants attended; 1 signed off.

1. Participants

Name	Role	Attended	Signed off
Jung Ko	CEO	10:51 PM	Jung Ko, 10:51 PM
Alex Rivera	CTO	No	Not signed
Morgan Chen	Head of Customer Success	No	Not signed

2. Scenario and injects used

A contractor commits an AWS access key to a public GitHub repository, and days later cloud alerts and a bill spike show someone is using it. The group must contain the key without breaking the production app on Vercel, decide whether customer data in RDS and S3 was taken, and decide who starts the 72-hour customer notice clock. The exercise tests role authority, secret rotation, outside-party contact and notification ownership.

#	Inject	Planned	Shown
1	Billing alert and GuardDuty finding	Start	10:41 PM
2	The key is in a public repository	+10 min	10:42 PM
3	Rotation partly breaks Vercel	+25 min	10:43 PM

3. Decision timeline

Time	Inject	Who	Decision
10:42 PM	Inject 1	Alex Rivera	Declare SEV1; Alex is Incident Commander, Morgan is Scribe (Phone tree used, Slack treated as suspect.)
10:43 PM	Inject 2	Team	Deactivate the leaked key in IAM before looking at what it touched (Lead Engineer rotates the RDS password and the Stripe and GitHub tokens next)

10:45 PM	Inject 3	Jung Ko	Call At-Bay before engaging any outside forensics firm (Policy number not to hand)

4. Executive summary

What was tested

Ledgerline ran a cloud credential drill on Oct 14, 2026 (10:39 PM to 10:47 PM, 8 minutes) against plan version 2. The scenario: a contractor leaks an AWS access key in a public GitHub repository, and someone then uses it, shown by a billing alert and a GuardDuty finding (AWS's threat-detection alert).

Who took part

Only the **CEO** attended and signed off. The **CTO** and the **Head of Customer Success** did not attend and have not signed off. Their decisions below were logged but were not made by them in the room.

Headline result

The team declared SEV1 (highest severity) at 10:42 PM, deactivated the leaked key at 10:43 PM and chose to call the cyber insurer first at 10:45 PM. The main weakness: nobody could find the At-Bay policy number or claims line.

Key findings

- Fast, decisive containment and clear role assignment.
- **High:** insurer contact details were not to hand.
- Only 3 of 5 planned participants' perspectives were present; the injects reached only part of the scenario's questions (notice clock ownership was not decided).

5. What went well

- **Quick, authorised action.** The strengths record notes the **CTO** held admin access to AWS and GitHub and acted within five minutes. The log shows SEV1 declared at 10:42 PM, one minute after the first inject appeared at 10:41 PM.
- **Clear roles.** The decision named the **CTO** as Incident Commander (the person leading the response) and the **Head of Customer Success** as Scribe (the note-taker).
- **Careful communication.** The notes say the phone tree was used and Slack treated as suspect, which makes sense if an attacker may be watching internal channels.
- **Sensible containment order.** At 10:43 PM the team deactivated the key in IAM (AWS's access control) before investigating, then planned to rotate the RDS password and the Stripe and GitHub tokens.
- **Insurer before forensics.** At 10:45 PM the **CEO** chose to call At-Bay before hiring an outside forensics firm, which helps protect insurance coverage.

6. Gaps and risks

1. Insurer contacts unavailable (high)

At inject 3 (10:45 PM), the **CEO** decided to call At-Bay first, but the notes say the policy number was not to hand, and the gap record states nobody could find the policy number or claims line. Cyber insurers often require prompt notice of an incident, and delay or hiring a firm without approval can put a claim at risk. Ledgerline's cyber insurance obligation makes this the most important gap.

2. Key participants absent

The **CTO** and **Head of Customer Success** did not attend, although the log attributes decisions to them. We cannot show from this record that they understand their assigned roles. This is a gap in evidence, not a judgement of the people.

3. Items not recorded or unresolved

- The scenario asked who starts the 72-hour customer notice clock. No decision on this was logged.
- The scenario's Vercel rotation problem (inject 3) produced no logged decision on keeping production running.
- The parking lot question remains open: does the enterprise MSA clock start at discovery or at confirmation? Counsel (Marlowe & Finch) should be asked.

7. Action plan

One action item was recorded:

1. **Put the insurer and counsel contacts in the appendix contact list.** Owner: **Head of Operations**. Due: 2026-10-28. Closes the high-severity gap that nobody could find the At-Bay policy number or claims line.

Not yet assigned

The following were raised but have no recorded action item, owner or date:

- The parking lot question on whether the enterprise MSA clock starts at discovery or at confirmation, to be put to Marlowe & Finch.
- Notification ownership for the 72-hour clock, and the Vercel rotation decision, which were not logged.
- Participation by the **CTO** and **Head of Customer Success**, who have not signed off.

The facilitator may wish to assign these before the next review.

8. Facilitator's closing note

Test again within 12 months, or sooner if the plan changes materially. At the next plan review, bring this report, confirmation that the contact list appendix was updated by 2026-10-28, the counsel answer on the MSA clock, and sign-off from the absent participants. All good.

9. Findings

Strengths observed

Strength
Alex had admin access to AWS and GitHub and acted within five minutes.

Gaps

Gap	Severity
Nobody could find the At-Bay policy number or claims line.	high

Action items

Action	Owner	Due
put the insurer and counsel contacts in the appendix contact list	Head of Operations	2026-10-28

Parking lot

Does the enterprise MSA clock start at discovery or at confirmation? Ask Marlowe & Finch.

10. Control mapping

The controls this exercise gives evidence toward, from the injects that were used. It does not, on its own, make the company compliant with any framework.

Control	What it asks for
SOC 2 CC7.3	Security events are evaluated to decide whether they are incidents
ISO 27001 A.5.24	Incident management is planned and prepared for
SOC 2 CC7.4	Identified incidents are handled through a defined response program
NIST CSF ID.IM-04	Incident response plans are established, maintained and improved
NIST 800-171 3.6.1	An operational incident-handling capability is established

11. Attestation

This report was generated by Valmius on Oct 17, 2026, 10:03 PM (America/Denver) from the exercise record, including server-timestamped decisions and participant sign-offs.

Report id: b96ae88e-b481-4d7b-9017-68101d627e0e, version 1.

Content fingerprint (SHA-256 of the report data): 5567df8ba80a19cde167bc633cbdc386188980f965a4098d0be2876c81b59d3d

The SHA-256 of this PDF file is recorded in the Valmius evidence vault (localhost:3000) and shown beside the download. A file whose hash matches that record is unaltered.